

Memoria Tecnica - Practica Red Team Recon

Reconocimiento externo controlado sobre programa HackerOne - Unico IDtech

Estudiante	Gabriel Gutierrez
Modulo	Practica Red Team
Entorno	Laboratorio controlado / VMware
Fecha	Junio 02 - 2026
Formato de entrega	PDF

Indice

1. Resumen ejecutivo
2. Objetivo
3. Alcance y consideraciones eticas
4. Programa y scope seleccionado
5. Metodologia
6. Herramientas utilizadas
7. Preparacion del entorno
8. Enumeracion de subdominios
9. Resolucion DNS
10. Deteccion de servicios HTTP/HTTPS vivos
11. Clasificacion de codigos HTTP y tecnologias
12. Escaneo Nuclei controlado
13. Recoleccion de URLs con Katana
14. Analisis de JavaScript y URLs interesantes
15. Resultados consolidados
16. Hallazgos y observaciones
17. Recomendaciones
18. Conclusion
19. Anexos de comandos

1. Resumen ejecutivo

Este documento presenta el reconocimiento externo realizado sobre activos del programa Unico IDtech en HackerOne. El trabajo se centro en identificar superficie expuesta de forma controlada, sin explotacion de vulnerabilidades, sin fuerza bruta y sin acciones intrusivas.

El flujo de trabajo tomo como referencia una metodologia de reconocimiento tipo Bug Bounty, replicada mediante herramientas publicas: subfinder, dnsx, httpx, nuclei y katana. Se revisaron activos incluidos en el scope del programa, se enumeraron subdominios, se resolvieron registros DNS, se identificaron servicios HTTP/HTTPS vivos, se analizaron tecnologias expuestas y se recolectaron URLs y archivos JavaScript.

Como resultado, se identificaron 192 subdominios mediante subfinder, 198 dominios unicos analizados, 133 hosts unicos con resolucion DNS, 123 URLs HTTP/HTTPS vivas, 3417 URLs recolectadas por Katana, 205 archivos JavaScript y 462 URLs consideradas interesantes por patrones de nombre. El escaneo con Nuclei no produjo hallazgos automatizados reportables en el archivo final de resultados.

2. Objetivo

El objetivo fue realizar un reconocimiento externo controlado sobre activos autorizados de un programa publico de Bug Bounty, documentando la superficie expuesta sin ejecutar explotacion ni pruebas intrusivas.

- Definir un scope valido a partir de HackerOne.
- Enumerar subdominios asociados al scope.
- Resolver registros DNS y determinar hosts activos.
- Detectar servicios HTTP/HTTPS vivos.
- Identificar codigos HTTP, titulos y tecnologias.
- Ejecutar Nuclei de forma controlada para detectar hallazgos automatizados.
- Recolectar URLs y recursos JavaScript con Katana.
- Priorizar activos y observaciones para un analisis defensivo.

3. Alcance y consideraciones eticas

El alcance se limito a activos marcados como in scope y elegibles dentro del programa Unico IDtech en HackerOne. Se excluyeron activos de tipo funcional sensible, pruebas de liveness bypass, aplicaciones moviles y cualquier elemento que pudiera requerir interaccion invasiva.

Importante: El reconocimiento realizado fue pasivo o semi-pasivo. No se realizo explotacion, fuerza bruta, bypass de autentificacion, fuzzing agresivo, intrusiones ni acceso a cuentas de usuarios reales.

4. Programa y scope seleccionado

Se selecciono el programa Unico IDtech desde HackerOne. Se consideraron activos marcados como Domain, Wildcard o URL dentro del scope. Para mantener el analisis controlado, el foco principal fue el dominio unico.io y activos asociados.

Tipo	Activo incluido en scope
Dominio	unico.io
Dominio	secure.unico.io
Dominio	openfinance.unico.io
Dominio	issuer.idpay-uat.unico.io
Dominio	idpay-uat.unico.io
Dominio	identityhomolog.acesso.io

Tipo	Activo incluido en scope					
Dominio	idcash-uat.unico.io					
Dominio	backend-sdk.uat.private.unico.run					
Dominio	accountshomolog.acesso.io					
Dominio	devcenter.unico.io					
Dominio	blog.unico.io					
Wildcard base	uat.unico.app					
Wildcard base	cadastro.uat.unico.app					
URL base	sdk-h1.unico.io					

Asset name ↑	Type ↑	Coverage ↑	Max. severity ↓	Bounty ↑	Last update ↑	Resolved Reports ⓘ ↑
unico.io	Domain	In scope	Critical	Eligible	Jan 16, 2026	1 (4%)
secure.unico.io	Domain	In scope	Critical	Eligible	Jan 16, 2026	0 (0%)
openfinance.unico.io	Domain	In scope	Critical	Eligible	Jan 16, 2026	0 (0%)
issuer.idpay-uat.unico.io	Domain	In scope	Critical	Eligible	Jan 16, 2026	0 (0%)
idpay-uat.unico.io	Domain	In scope	Critical	Eligible	Jan 16, 2026	0 (0%)
identityhomolog.acesso.io	Domain	In scope	Critical	Eligible	Jan 14, 2026	0 (0%)
*.uat.unico.app	Wildcard	In scope	Critical	Eligible	Jan 14, 2026	1 (4%)
*.cadastro.uat.unico.app Scope related to the By Unico API.	Wildcard	In scope	Critical	Eligible	Nov 12, 2025	0 (0%)
https://sdk-h1.unico.io/createprocess Scope related to Unico Liveness Testing. This endpoint is used for the final liveness validation.	URL	In scope	High	Eligible	Jan 16, 2026	0 (0%)
devcenter.unico.io	Domain	In scope	Medium	Eligible	Jan 16, 2026	0 (0%)
blog.unico.io	Domain	In scope	Medium	Eligible	Jan 16, 2026	0 (0%)

Captura 1 - Scope del programa Unico IDtech en HackerOne.

5. Metodologia

La metodologia fue estructurada en fases. Primero se definio el scope, luego se enumeraron subdominios, se resolvieron DNS, se detectaron servicios HTTP/HTTPS vivos, se clasificaron tecnologias y codigos HTTP, se ejecuto Nuclei de forma controlada y finalmente se recolectaron URLs y recursos JavaScript mediante Katana.

Fase	Herramienta	Resultado esperado
Scope	HackerOne	Definir activos permitidos.
Subdominios	subfinder	Encontrar subdominios asociados.
DNS	dnsx	Determinar hosts que resuelven.

Fase	Herramienta	Resultado esperado
HTTP/HTTPS	httpx	Detectar URLs vivas, codigos, titulos y tecnologias.
Templates	nuclei	Detectar hallazgos automatizados no intrusivos.
URLs/JS	katana	Recolectar rutas, endpoints y archivos JS.

Al no disponer de una herramienta privada tipo Cerberus Search, el flujo fue reproducido con herramientas publicas equivalentes y comandos reproducibles.

6. Herramientas utilizadas

Herramienta	Uso en la practica
subfinder	Enumeracion de subdominios.
dnsx	Resolucion de registros A, AAAA y CNAME.
httpx	Identificacion de servicios HTTP/HTTPS vivos, titulos, codigos y tecnologias.
nuclei	Revision automatizada controlada de hallazgos conocidos.
katana	Crawling controlado para obtener URLs y recursos JavaScript.
grep / sort / wc / cut	Procesamiento de archivos y resumen de resultados.

7. Preparacion del entorno

Se creo una carpeta de trabajo para almacenar resultados crudos, procesados y capturas.

```
mkdir -p ~/recon_unico/{raw,processed,screenshots}
cd ~/recon_unico
```

Luego se creo el archivo scope.txt con 14 activos base definidos a partir del scope del programa.

```
cat > scope.txt << 'EOF'
unico.io
secure.unico.io
openfinance.unico.io
issuer.idpay-uat.unico.io
idpay-uat.unico.io
identityhomolog.acesso.io
idcash-uat.unico.io
backend-sdk.uat.private.unico.run
accountshomolog.acesso.io
devcenter.unico.io
blog.unico.io
uat.unico.app
cadastro.uat.unico.app
sdk-h1.unico.io
EOF
```

```
(kali@kali)-[~/recon_unico]
$ cat scope.txt
wc -l scope.txt
14 scope.txt
unico.io
secure.unico.io
openfinance.unico.io
issuer.idpay-uat.unico.io
idpay-uat.unico.io
identityhomolog.acesso.io
idcash-uat.unico.io
backend-sdk.uat.private.unico.run
accountshomolog.acesso.io
devcenter.unico.io
blog.unico.io
uat.unico.app
cadastro.uat.unico.app
sdk-h1.unico.io
```

Captura 2 - Archivo scope.txt con 14 activos iniciales.

8. Enumeracion de subdominios

Se ejecuto subfinder sobre cada activo definido en scope.txt para identificar subdominios asociados.

```
while read d; do
    subfinder -d "$d" -all -silent
done < scope.txt | sort -u > raw/subdomains_subfinder.txt
```

El resultado fue de 192 subdominios encontrados mediante subfinder.

```
(kali@kali)-[~/recon_unico]
$ while read d; do
    subfinder -d "$d" -all -silent
done < scope.txt | sort -u > raw/subdomains_subfinder.txt

(kali@kali)-[~/recon_unico]
$ wc -l raw/subdomains_subfinder.txt
192 raw/subdomains_subfinder.txt
head -20 raw/subdomains_subfinder.txt
192 raw/subdomains_subfinder.txt
accounts-corp.unico.io
accounts-test.unico.io
accounts.unico.io
admin.people.uat.unico.app
admin.uat.unico.app
ajuda.unico.io
alpha.idpay.unico.io
api.cadastro.uat.unico.app
api.client.safeapp.uat.unico.app
api.idcash.uat.unico.app
api.idcloud.uat.unico.app
api.id.uat.unico.app
api.people.uat.unico.app
api.portal.safeapp.uat.unico.app
api.radar.uat.unico.app
api.safeapp.uat.unico.app
api.shortener.uat.unico.app
api.webhook.uat.unico.app
api.you.uat.unico.app
api-you.unico.io
```

Captura 3 - Resultado de subfinder con 192 subdominios.

9. Resolucion DNS

Se unifico el scope inicial con los subdominios encontrados para crear una lista unica de dominios a analizar.

```
cat scope.txt raw/subdomains_subfinder.txt | sort -u > processed/all_domains.txt
```

Luego se resolvieron registros A, AAAA y CNAME mediante dnsx.

```
dnsx -l processed/all_domains.txt -a -aaaa -cname -resp -silent -o processed/resolved_dns.txt
```

Se obtuvieron 414 registros DNS y 133 hosts unicos con resolucion. En la salida se observaron activos detras de proveedores como Cloudflare, Google Cloud, Vercel, Zendesk, HubSpot, GitBook y CloudFront.

Metrica DNS	Resultado
Dominios unicos analizados	198
Registros DNS encontrados	414
Hosts unicos que resuelven	133

```
(kali@kali)-[~/recon_unico]
└─$ wc -l processed/all_domains.txt processed/resolved_dns.txt processed/resolved_hosts.txt
head -20 processed/resolved_dns.txt
198 processed/all_domains.txt
414 processed/resolved_dns.txt
133 processed/resolved_hosts.txt
745 total
api-you.unico.io [A] [107.178.244.248]
clicks.unico.io [A] [34.149.213.213]
int-api-you.unico.io [A] [10.28.3.212]
accounts-corp.unico.io [A] [34.102.189.132]
api.id.uat.unico.app [A] [104.18.2.53]
api.id.uat.unico.app [A] [104.18.3.53]
api.id.uat.unico.app [AAAA] [2606:4700::6812:235]
api.id.uat.unico.app [AAAA] [2606:4700::6812:335]
api.id.uat.unico.app [CNAME] [api.id.uat.unico.app.cdn.cloudflare.net]
indicacaoskill.unico.io [A] [185.158.133.1]
eu.unico.io [A] [34.107.142.238]
blog.unico.io [A] [104.18.28.56]
blog.unico.io [A] [104.18.29.56]
blog.unico.io [AAAA] [2606:4700::6812:1d38]
blog.unico.io [AAAA] [2606:4700::6812:1c38]
blog.unico.io [CNAME] [blog.unico.io.cdn.cloudflare.net]
ajuda.unico.io [A] [35.186.208.128]
admin.people.uat.unico.app [A] [35.241.55.167]
cdn.people.uat.unico.app [A] [35.241.55.167]
devcenter.unico.io [A] [104.18.40.47]

(kali@kali)-[~/recon_unico]
└─$
```

Captura 4 - Resolucion DNS con dnsx.

10. Deteccion de servicios HTTP/HTTPS vivos

A partir de los hosts resueltos se ejecuto httpx de ProjectDiscovery para identificar servicios web vivos, codigos HTTP, titulos y tecnologias.

```
cut -d' ' -f1 processed/resolved_dns.txt | sort -u > processed/resolved_hosts.txt
~/go/bin/httpx -l processed/resolved_hosts.txt -title -tech-detect -status-code -follow-redirects -silent
-o processed/httpx_alive.txt
```

Se detectaron 123 URLs HTTP/HTTPS vivas. Posteriormente se separaron los resultados por codigo HTTP.

Codigo HTTP	Cantidad
200	22
301	0
302	0
403	37
404	25
Total URLs vivas	123

```

└─$ ~/go/bin/httpx -l processed/resolved_hosts.txt -title -tech-detect -status-code -follow-redirects -silent -o processed/httpx_alive.txt
https://e2e.web.sdk.uat.fwdrule.unico.io [403] [403] [HTTP/3]
https://api.portal.safeapp.uat.unico.app [401] [Google Cloud,Google Cloud CDN,HTTP/3]
https://developer.dev.unico.io [403] [403] [HSTS,HTTP/3]
https://blog.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://api-you.unico.io [404] [Google Cloud,Google Cloud CDN,HTTP/3]
https://developer-uat.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://idcash-dev.unico.io [403] [403] [HSTS,HTTP/3]
https://callback.openfinance.unico.io [404] [Google Cloud,Google Cloud CDN,Google Cloud Load Balancing,Google Cloud Trace,HSTS,HTTP/3]
https://cdn.people.uat.unico.app [404] [Envoy,Google Cloud,Google Cloud CDN,HTTP/3]
https://idpay-dev.unico.io [403] [403] [HSTS,HTTP/3]
https://creditcard.transactional.uat.unico.app [403] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://cadastro.uat.unico.app [404] [Unico] [Cloudflare,Cloudflare Bot Management,Cloudflare Browser Insights,Google Cloud,Google Cloud CDN,Google Cloud Storage,HSTS]
https://api.webhook.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://backend-sdk.uat.private.unico.run [] [Google Cloud,Google Cloud CDN,HTTP/3]
https://clicks.unico.io [404] [404 Not Found] [Google Cloud,Google Cloud CDN,HTTP/3]
https://form.people.uat.unico.app [200] [Unico] [Envoy,Google Cloud,Google Cloud CDN,HSTS,HTTP/3]
https://gtm.unico.io [404]
https://api.idcash.uat.unico.app [404] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://api.cadastro.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://api.idcloud.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://consumer.openfinance.unico.io [404] [Google Cloud,Google Cloud CDN,Google Cloud Load Balancing,Google Cloud Trace,HSTS,HTTP/3]
https://api.you.uat.unico.app [404] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://developer.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://api.id.uat.unico.app [404] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN,HSTS]
https://issuer.idpay-dev.unico.io [403] [403] [HSTS,HTTP/3]
https://api.shortener.uat.unico.app [404] [Google Cloud,Google Cloud CDN,HTTP/3]
https://api.safeapp.uat.unico.app [415] [Google Cloud,Google Cloud CDN,HTTP/3]
https://accounts.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://id.uat.unico.app [404] [Unico] [Cloudflare,Cloudflare Bot Management,Cloudflare Browser Insights,Google Cloud,Google Cloud CDN,Google Cloud Storage]
https://idcash-uat.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://idcash.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://ajuda.unico.io [301,403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management]
https://carreiras.unico.io [301,403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management]
https://api.people.uat.unico.app [404] [Envoy,Google Cloud,Google Cloud CDN,HTTP/3]
https://mobile-integration.unico.io [404] [Google Cloud,Google Cloud CDN,HSTS,HTTP/3]
https://admin.people.uat.unico.app [200] [Unico People] [Envoy,Google Cloud,Google Cloud CDN,HSTS,HTTP/3]
https://issuer.idpay-uat.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://issuer.idpay.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://diagnosticodho.unico.io [403] [Cloudflare,Cloudflare Bot Management,HSTS]
https://cloud.mkt.unico.io [404]
https://click.mkt.unico.io [403] [403 - Forbidden: Access is denied.] [HSTS]
https://fileserv.transactional.uat.unico.app [403] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://cdn.unico.io [200] [Google Cloud,Google Cloud Storage,HSTS,HTTP/3]
https://portal.sdk.unico.uat.fwdrule.unico.io [403] [403] [HTTP/3]
https://backoffice.openfinance.unico.io [200] [HSTS,Next.js,Node.js,React,Vercel,Webpack]
https://gamesegurancaeprivacidade.unico.io [200] [Reinos Inegociáveis] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN,HSTS,HTTP/3]
https://ms.api.id.uat.unico.app [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,Cloudflare Browser Insights]
https://id.unico.io [404] [Unico] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN,Google Cloud Storage,HTTP/3]
https://puzzle.unico.io [403] [403] [HSTS,HTTP/3]
https://microblink.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]

```

Captura 5 - httpx detectando servicios web vivos.

```

(kali@kali) ~/recon_unico
└─$ wc -l processed/httpx_alive.txt
wc -l processed/http_200.txt processed/http_301.txt processed/http_302.txt processed/http_403.txt processed/http_404.txt
head -20 processed/httpx_alive.txt
123 processed/httpx_alive.txt
22 processed/http_200.txt
0 processed/http_301.txt
0 processed/http_302.txt
37 processed/http_403.txt
25 processed/http_404.txt
84 total
https://e2e.web.sdk.uat.fwdrule.unico.io [403] [403] [HTTP/3]
https://api.portal.safeapp.uat.unico.app [401] [Google Cloud,Google Cloud CDN,HTTP/3]
https://developer.dev.unico.io [403] [403] [HSTS,HTTP/3]
https://blog.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://api-you.unico.io [404] [Google Cloud,Google Cloud CDN,HTTP/3]
https://developer-uat.unico.io [403] [Attention Required! | Cloudflare] [Cloudflare,Cloudflare Bot Management,HTTP/3]
https://idcash-dev.unico.io [403] [403] [HSTS,HTTP/3]
https://callback.openfinance.unico.io [404] [Google Cloud,Google Cloud CDN,Google Cloud Load Balancing,Google Cloud Trace,HSTS,HTTP/3]
https://cdn.people.uat.unico.app [404] [Envoy,Google Cloud,Google Cloud CDN,HTTP/3]
https://idpay-dev.unico.io [403] [403] [HSTS,HTTP/3]
https://creditcard.transactional.uat.unico.app [403] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://cadastro.uat.unico.app [404] [Unico] [Cloudflare,Cloudflare Bot Management,Cloudflare Browser Insights,Google Cloud,Google Cloud CDN,Google Cloud Storage,HSTS]
https://api.webhook.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://backend-sdk.uat.private.unico.run [] [Google Cloud,Google Cloud CDN,HTTP/3]
https://clicks.unico.io [404] [404 Not Found] [Google Cloud,Google Cloud CDN,HTTP/3]
https://form.people.uat.unico.app [200] [Unico] [Envoy,Google Cloud,Google Cloud CDN,HSTS,HTTP/3]
https://gtm.unico.io [404]
https://api.idcash.uat.unico.app [404] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://api.cadastro.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
https://api.idcloud.uat.unico.app [] [Cloudflare,Cloudflare Bot Management,Google Cloud,Google Cloud CDN]
(kali@kali) ~/recon_unico

```

Captura 6 - Resumen de codigos HTTP.

11. Clasificacion de codigos HTTP y tecnologias

Los resultados de httpx permitieron identificar servicios protegidos o restringidos mediante codigos 403, recursos no encontrados con 404 y activos accesibles con 200. Tambien se observaron tecnologias y proveedores como Cloudflare, Google Cloud, Vercel, Zendesk, HubSpot, GitBook y CloudFront.

Los codigos 403 no se consideran vulnerabilidad por si mismos. En este contexto indican que existen servicios publicados con acceso restringido, lo que puede ser normal en aplicaciones protegidas o paneles internos expuestos a internet pero controlados por autenticacion o reglas de acceso.

12. Escaneo Nuclei controlado

Se ejecuto Nuclei sobre los activos HTTP/HTTPS vivos. Debido al tiempo de ejecucion y para mantener un enfoque controlado, no se realizaron pruebas agresivas. El archivo final de resultados quedo sin hallazgos reportables.

```
nuclei -l processed/alive_urls.txt -severity low,medium,high,critical -rl 5 -c 5 -o
processed/nuclei_results.txt
```

El archivo processed/nuclei_results.txt quedo con 0 lineas, por lo que no se identificaron hallazgos automatizados reportables durante esta revision.

```
(kali㉿kali)-[~/recon_unico]
$ nuclei -l processed/alive_urls.txt \
-severity high,critical \
-rl 2 \
-c 2 \
-timeout 5 \
-retries 0 \
-o processed/nuclei_high_critical.txt
File System
Nuclei v3.8.0
projectdiscovery.io

^[[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[B^[INF] Current nuclei version: v3.8.0 (latest)
[INF] Current nuclei-templates version: v10.4.4 (latest)
[INF] New templates added in latest release: 179
[INF] Templates loaded for current scan: 4083
[INF] Executing 4082 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 1 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 123
[INF] Templates clustered: 273 (Reduced 28536 Requests)
^C[INF] CTRL+C pressed: Exiting
[INF] Attempting graceful shutdown ...
[INF] Creating resume file: /home/kali/.cache/nuclei/resume-d8f6no2o12pua85jk7bg.cfg

(kali㉿kali)-[~/recon_unico]
$ wc -l processed/nuclei_results.txt
0 processed/nuclei_results.txt
```

Captura 7 - Nuclei sin hallazgos reportables.

13. Recoleccion de URLs con Katana

Se utilizo Katana con profundidad 1 para recolectar URLs, rutas y recursos accesibles desde los servicios web vivos.

```
~/go/bin/katana -list processed/alive urls.txt -depth 1 -silent -o processed/katana urls.txt
```

Katana recolecto 3417 URLs. Esta informacion permite ampliar la vision de superficie web, identificando rutas, recursos estaticos, endpoints y archivos JavaScript.

```

(kali@kali) - [~/recon_unico]
$ wc -l processed/katana_urls.txt
head -30 processed/katana_urls.txt
3417 processed/katana_urls.txt
https://svc.people.uat.unico.app
https://form.people.uat.unico.app
https://api.client.safeapp.uat.unico.app
https://callback.openfinance.unico.io
https://id.uat.unico.app
https://creditcard.transactional.uat.unico.app
https://id.uat.unico.app/
https://fp.unico.app
https://backend-sdk.prod.private.unico.run
https://backend-sdk.prod.private.unico.run
https://id.uat.unico.app/assets/vendor-monitoring-CNa00KwT.js
https://id.uat.unico.app/
https://js.sentry-cdn.com/7bbafa01761f4797ad3ae8f2d37d9alb.min.js
https://id.uat.unico.app/assets/index-CEfwYBtE.js
https://static.cloudflareinsights.com/beacon.min.js/v833ccba57c9e4d2798f2e76cebdd09a11778172276447
https://paraempresas-skill.unico.io/hc/pt-br
https://brand.unico.io
https://form.people.uat.unico.app/assets/js/userguiding.js
https://form.people.uat.unico.app/assets/js/env5.ef5f9c52b00e3f87c959.js
https://form.people.uat.unico.app/runtime-es5.d53061b84fc2f80eb94e.js
https://form.people.uat.unico.app/runtime-es2015.d53061b84fc2f80eb94e.js
https://form.people.uat.unico.app/assets/js/load-image.all.min.js
https://form.people.uat.unico.app/main-es2015.8a25c9ae12b0859b192c.js
https://apolo-idpay.unico.io/hc/pt-br
https://id.uat.unico.app/assets/index-CEfwYBtE.js
https://id.uat.unico.app/assets/index-CEfwYBtE.js
https://api.whatsapp.com/send?phone=5511503931886&text=01%2C%20estou%20em%20processo%20de%20admiss%C3%A3o%20e%20preciso%20de%20ajuda.5type=phone_number&app_absent=0
https://form.people.uat.unico.app/main-es2015.8a25c9ae12b0859b192c.js
https://form.people.uat.unico.app/main-es5.8a25c9ae12b0859b192c.js
https://form.people.uat.unico.app/polyfills-es2015.9f98264ccf6dc9813354.js

```

Captura 8 - Katana recolectando URLs.

14. Analisis de JavaScript y URLs interesantes

A partir de las URLs recolectadas se extrajeron archivos JavaScript y rutas con patrones de interes como api, auth, login, admin, callback, token, oauth, sso, webhook, upload, download, assets y static.

```
grep -Ei "\.js($|\?)" processed/katana_urls.txt | sort -u > processed/katana_js.txt
```

```
grep -Ei "api|auth|login|admin|callback|portal|token|oauth|sso|webhook|upload|download|assets|static"
processed/katana_urls.txt | sort -u > processed/interesting_urls.txt
```

Elemento	Cantidad
URLs recolectadas por Katana	3417
Archivos JavaScript identificados	205
URLs interesantes filtradas	462

Estos resultados no representan vulnerabilidades por si mismos. Su utilidad principal es orientar revisiones posteriores de superficie web, endpoints, integraciones y recursos del lado cliente.

Captura 9 - Archivos JavaScript identificados.

Captura 10 - URLs interesantes filtradas.

15. Resultados consolidados

Bloque Recon	Resultado
Activos iniciales en scope	14
Subdominios encontrados con subfinder	192
Dominios unicos analizados	198
Registros DNS obtenidos	414
Hosts unicos que resuelven DNS	133
URLs HTTP/HTTPS vivas	123
URLs recolectadas con Katana	3417
Archivos JavaScript identificados	205
URLs interesantes filtradas	462
Hallazgos reportables con Nuclei	0

```
(kali㉿kali)-[~/recon_unico]
$ wc -l scope.txt \
raw/subdomains_subfinder.txt \
processed/all_domains.txt \
processed/resolved_dns.txt \
processed/resolved_hosts.txt \
processed/httpx_alive.txt \
processed/katana_urls.txt \
processed/katana_js.txt \
processed/interesting_urls.txt \
processed/nuclei_results.txt
  14 scope.txt
 192 raw/subdomains_subfinder.txt
 198 processed/all_domains.txt
 414 processed/resolved_dns.txt
 133 processed/resolved_hosts.txt
 123 processed/httpx_alive.txt
3417 processed/katana_urls.txt
 205 processed/katana_js.txt
 462 processed/interesting_urls.txt
   0 processed/nuclei_results.txt
5158 total

(kali㉿kali)-[~/recon_unico]
$
```

Captura 11 - Resumen final de archivos y conteos.

La captura muestra el resumen final de archivos generados durante el reconocimiento. Se consolidan 14 activos iniciales en scope, 192 subdominios encontrados, 198 dominios únicos analizados, 414 registros DNS obtenidos, 133 hosts con resolución DNS, 123 URLs HTTP/HTTPS vivas, 3417 URLs recolectadas con Katana, 205 archivos JavaScript, 462 URLs interesantes y 0 hallazgos reportables con Nuclei.

16. Hallazgos y observaciones

No se identificaron hallazgos automatizados reportables con Nuclei. Sin embargo, el reconocimiento permitio mapear una superficie considerable de activos web, incluyendo entornos UAT, endpoints API, portales, recursos de marketing, documentacion y servicios gestionados por proveedores externos.

Observacion	Interpretacion
Presencia de multiples activos UAT	Conviene revisar controles de acceso, autenticacion y exposicion de entornos no productivos.
Uso de Cloudflare y otros CDN	Indica proteccion y distribucion de servicios, pero requiere revisar configuraciones de origen.
Servicios en Zendesk, HubSpot, GitBook, Vercel y CloudFront	Dependencias de terceros deben mantenerse dentro del inventario y revisarse segun scope.
Elevado numero de URLs y JS	Sugiere superficie web amplia para revision manual posterior.
Nuclei sin hallazgos	No se detectaron vulnerabilidades automatizadas reportables en esta pasada controlada.

17. Recomendaciones

- Mantener inventario actualizado de subdominios y activos expuestos.
- Revisar periodicamente entornos UAT, dev y homologacion expuestos publicamente.
- Validar que los activos con codigo 403 no filtren informacion sensible en cabeceras, titulos o respuestas de error.
- Monitorear CNAME hacia proveedores externos para evitar subdomain takeover si un servicio queda desprovisionado.
- Revisar archivos JavaScript para detectar endpoints, claves publicas, rutas internas o referencias a ambientes no productivos.
- Aplicar controles de seguridad consistentes en dominios principales, subdominios, portales y APIs.
- Ejecutar revisiones periodicas con herramientas de reconocimiento y complementar con analisis manual bajo scope autorizado.
- Documentar activos de terceros asociados al dominio y verificar responsabilidades de seguridad compartida.

18. Conclusion

El reconocimiento externo permitio identificar y clasificar la superficie publica asociada al programa Unico IDtech dentro del scope revisado. Se obtuvieron 192 subdominios, 133 hosts resolviendo DNS, 123 servicios HTTP/HTTPS vivos y 3417 URLs recolectadas mediante crawling controlado.

No se detectaron hallazgos automatizados reportables con Nuclei en el archivo final de resultados, por lo que el foco del informe queda en la visibilidad de activos, clasificacion de superficie, tecnologias observadas y recomendaciones defensivas. El resultado es una base util para priorizar revisiones manuales posteriores dentro del scope autorizado.

19. Anexos de comandos

```
# Crear estructura
mkdir -p ~/recon_unico/{raw,processed,screenshots}
cd ~/recon_unico

# Subdominios
while read d; do
    subfinder -d "$d" -all -silent
done < scope.txt | sort -u > raw/subdomains_subfinder.txt

# DNS
cat scope.txt raw/subdomains_subfinder.txt | sort -u > processed/all_domains.txt
dnsx -l processed/all_domains.txt -a -aaaa -cname -resp -silent -o processed/resolved_dns.txt
cut -d' ' -f1 processed/resolved_dns.txt | sort -u > processed/resolved_hosts.txt

# HTTP vivos
~/go/bin/httpx -l processed/resolved_hosts.txt -title -tech-detect -status-code -follow-redirects -silent
-o processed/httpx_alive.txt
cut -d' ' -f1 processed/httpx_alive.txt | sort -u > processed/alive_urls.txt

# Separar codigos HTTP
grep "[200]" processed/httpx_alive.txt > processed/http_200.txt
grep "[403]" processed/httpx_alive.txt > processed/http_403.txt
grep "[404]" processed/httpx_alive.txt > processed/http_404.txt

# Nuclei
nuclei -l processed/alive_urls.txt -severity low,medium,high,critical -r1 5 -c 5 -o
processed/nuclei_results.txt

# Katana
~/go/bin/katana -list processed/alive_urls.txt -depth 1 -silent -o processed/katana_urls.txt

# JavaScript y URLs interesantes
grep -Ei "\.js($|\?)" processed/katana_urls.txt | sort -u > processed/katana_js.txt
grep -Ei "api|auth|login|admin|callback|portal|token|oauth|sso|webhook|upload|download|assets|static"
processed/katana_urls.txt | sort -u > processed/interesting_urls.txt
```